

PENETRATION TESTING AGREEMENT

AGREEMENT ID: PTA-2025-111-PAROCYBER

EFFECTIVE DATE: 04-12-2025

PARTIES TO THIS AGREEMENT

SERVICE PROVIDER (PENETRATION TESTER)

Name: Ekene kingsley Iheme

Title: Independent Security Consultant

Company: Vesta Pharmacy Security Services

Address: 3 Oba-falabi street ojodu bustop, Berger

Phone: +2348035007625

Email: ekeneiheme02@gmail.com

CLIENT

Name: ParoCyber

Address: McCarthy Hill, Accra-Ghana

Contact Person: Mawuli

Title: IT Manager

Phone: +233 54 312 9758

Email: parocyber@gmail.com

1.0 INTRODUCTION AND PURPOSE

This Penetration Testing Agreement yields the terms, conditions, and scope under which Ekene kingsley Iheme (Tester) will perform authorized security testing services for ParoCyber (Client). This engagement follows industry-standard methodologies and ethical guidelines to identify security vulnerabilities while minimizing operational impact.

1.1 Key Principles

- Authorization: All testing is pre-authorized and documented
- Ethical Conduct: Testing follows responsible disclosure principles
- Professionalism: Engagement adheres to industry best practices
- Confidentiality: All findings are protected as sensitive information

2.0 SCOPE OF ENGAGEMENT

2.1 Authorized Systems and Targets

PRIMARY TARGETS:

- Domain: parocyber.com
- IP Range: [Approved IP Range]
- Subdomains: *.parocyber.com
- Web Applications: portal.parocyber.com, api.parocyber.com

EXCLUDED TARGETS:

- Production databases with live customer data - Third-party hosted services outside Client's control
- Any system not explicitly listed in Appendix A

2.2 Testing Methodology

The engagement will utilize a hybrid approach combining:

2.2.1 External Network Testing

- 🎬 Port scanning and service enumeration
- 🎬 Vulnerability assessment of exposed services
- 🎬 Firewall and perimeter security evaluation
- 🎬 DNS and infrastructure reconnaissance

2.2.2 Web Application Security Assessment

- 🎬 OWASP Top 10 vulnerability testing
- 🎬 Authentication and authorization testing
- 🎬 Business logic flaw analysis
- 🎬 API security testing (REST/SOAP endpoints)

2.2.3 Limited Internal Testing (if authorized)

- 🎬 Network segmentation testing
- 🎬 Internal service vulnerability assessment
- 🎬 Privilege escalation simulation

2.3 Testing Windows

PRIMARY TESTING PERIOD:

Start: December 1, 2025, 09:00 WAT

End: December 5, 2025, 16:00 WAT

Daily Window: 09:00 - 16:00 WAT (Business Hours)

EMERGENCY STOP PROCEDURE:

If critical issues are discovered, testing will pause immediately and Client will be notified within 10 minutes.

3.0 RULES OF ENGAGEMENT

3.1 Authorized Activities

The Tester is authorized to:

- 🎬 Conduct non-destructive exploitation for proof-of-concept
- 🎬 Use automated scanning tools within rate limits
- 🎬 Access test accounts provided by Client
- 🎬 Document findings with screenshots and evidence

3.2 Prohibited Activities

The Tester SHALL NOT:

- 🎬 Perform Denial of Service (DoS/DDoS) attacks
- 🎬 Modify or delete production data
- 🎬 Use social engineering without explicit authorization
- 🎬 Test outside agreed time windows
- 🎬 Disclose findings to third parties
- 🎬 Retain data beyond agreed retention period

3.3 Communication Protocol

IMMEDIATE (Within 15 minutes):

- Critical vulnerabilities (Remote Code Execution, Data Breach)
- Service disruption or unintended impact
- Legal/regulatory compliance concerns

DAILY (16:00 WAT):

- Daily summary report

- Progress update
- Any concerns or scope clarifications

FINAL (Post-engagement):

- Comprehensive technical report
- Executive briefing
- Remediation roadmap

4.0 LEGAL AND ETHICAL FRAMEWORK

4.1 Compliance & Standards

This engagement complies with:

- 🎬 Computer Fraud and Abuse Act (CFAA) 18 U.S.C. § 1030
- 🎬 Electronic Communications Privacy Act (ECPA)
- 🎬 State-specific computer crime laws

Industry Standards:

- 🎬 OWASP Testing Guide v4.0
- 🎬 PTES (Penetration Testing Execution Standard)
- 🎬 NIST SP 800-115
- 🎬 ISO/IEC 27001:2022

4.2 Data Handling & Privacy

4.2.1 Data Collection

- 🎬 Only collect minimum necessary data for vulnerability validation
- 🎬 Anonymize any captured sensitive information
- 🎬 Use encrypted storage for all collected data

4.2.2 Data Retention

- 🎬 Raw scan data: 30 days post-engagement
- 🎬 Final reports: 24 months (encrypted)
- 🎬 Complete destruction: After retention period

4.2.3 Privacy Protection

- 🎬 No collection of personally identifiable information (PII)
- 🎬 Respect employee and customer privacy
- 🎬 Follow Client's data protection policies

4.3 Responsible Disclosure

- 🎬 Vulnerabilities reported only to authorized Client contacts
- 🎬 No public disclosure without Client's written consent
- 🎬 90-day remediation period before considering disclosure

- Coordinate disclosure timing with Client's PR/legal teams

5.0 DELIVERABLES

5.1 Reporting Structure

5.1.1 Executive Summary (Non-technical)

- Business risk overview
- High-level findings
- Strategic recommendations
- Risk heat map

5.1.2 Technical Report

- Methodology details
- Vulnerability details (CVSS scores)
- Proof-of-concept evidence
- Reproduction steps
- Affected components

5.1.3 Remediation Guide

- Step-by-step fixes
- Configuration changes
- Code patches
- Verification steps

5.1.4 Raw Data Package (Optional)

- Scan outputs
- Tool logs
- Network captures

5.2 Delivery Timeline

WEEK 1:

- Kickoff meeting & scope confirmation
- Initial reconnaissance
- Vulnerability scanning

WEEK 2:

- Manual testing & exploitation
- Validation of findings
- Report drafting

WEEK 3:

- Report review with Client
- Remediation planning session
- Final report delivery

5.3 Quality Standards

- All vulnerabilities rated using CVSS v3.1
- Risk categorization (Critical/High/Medium/Low/Info)
- Business impact assessment
- Actionable remediation guidance

6.0 LIABILITY AND INSURANCE

6.1 Limitation of Liability

6.1.1 Service Provider Liability

Tester's maximum liability limited to:

- Direct damages up to 100% of engagement fee
- Excludes indirect, consequential, or punitive damages
- Subject to insurance coverage terms

6.1.2 Client Responsibilities

Client agrees to:

- Provide accurate system information
- Maintain system backups
- Designate technical contact points
- Respond to critical findings promptly

6.2 Insurance Coverage

Tester maintains:

- Professional Liability: \$2,000,000
- Cyber Liability: \$3,000,000
- General Liability: \$1,000,000
- Certificates available upon request.

6.3 Indemnification

6.3.1 Mutual Indemnification

Both parties agree to indemnify against:

- Breach of agreement terms
- Unauthorized actions by their personnel
- Violation of third-party rights

6.3.2 Client Indemnification

Client indemnifies Tester for:

- Testing authorized systems
- Following agreed methodologies
- Actions within defined scope

7.0 FEES AND PAYMENT TERMS

7.1 Engagement Fees

SERVICE	FEE	DUE DATE
Initial Assessment	\$2,000	Upon signing
Testing Phase	\$6,000	Start of testing

Report & Delivery	\$2,000	Report delivery
TOTAL	\$10,000	

7.2 Payment Terms

- Invoices net 15 days
- Late payment fee: 1.5% monthly
- Accepted: ACH, Wire Transfer, Credit Card
- Taxes: Client responsible for applicable sales tax

7.3 Additional Costs

- Scope changes require written approval
- Additional testing billed at \$150/hour
- Travel expenses (if applicable) at cost

8.0 TERM AND TERMINATION

8.1 Agreement Duration

Effective from signing through:

- Completion of all deliverables, OR
- 30 days after final report delivery, OR
- Mutual written agreement to terminate

8.2 Termination Rights

8.2.1 For Cause

Either party may terminate with 24 hours' notice for:

- Material breach of agreement
- Illegal or unauthorized activities
- Failure to make payments

8.2.2 Without Cause

- Client may terminate with 48 hours' notice
- Tester paid for work completed to date

8.3 Post-Termination

- Return of all Client materials
- Secure deletion of collected data
- Final invoice for completed work

9.0 CONFIDENTIALITY

9.1 Confidential Information

Includes but not limited to:

- Vulnerability details and findings
- System architecture information
- Client security controls
- Business processes and data

9.2 Non-Disclosure Period

- Findings: 5 years from engagement end
- Methodology: 2 years from engagement end
- Engagement existence: 1 year from engagement end

9.3 Permitted Disclosures

- As required by law (with prior notice to Client)
- To legal counsel for advice
- Anonymized in professional portfolios (with Client approval)

10.0 SIGNATURES

SERVICE PROVIDER

Name: Ekene Kingsley Iheme

Title: Security Consultant

Signature: E.Iheme

Date: 05-12-2025

Email: ekeneiheme02@gmail.com

Phone: +2348035007625

CLIENT

Name: Mawuli

Title: IT Manager

Company: ParoCyber

Signature:

Date: 05-12-2025

Email: parocyber@gmail.com

Phone: +233 54 312 9758

APPENDICES**Appendix A: Detailed Scope Document**

Specific IPs, URLs, credentials

Appendix B: Communication Contacts**PRIMARY TECHNICAL CONTACT:**

Name: Jade

Role: Senior System Administrator

Email: jade.s.admin@parocyber.com

Phone: (555) 123-4567

Emergency: (555) 987-6543

SECURITY CONTACT:

Name: Alex Johnson

Role: Chief Security Officer (CSO)

Email: alex.johnson@parocyber.com

Phone: (555) 234-5678

LEGAL CONTACT:

Name: Sarah Chen

Role: Corporate Counsel

Email: sarah.chen@parocyber.com

Phone: (555) 345-6789

Appendix C: Testing Schedule

See attached Penetration Testing Agreement plan v2. Testing will run from Monday 1st to Friday 5th, 2025, 08:00 to 16:00WAT daily

Appendix D: Tools & Techniques

Tools include: NMAP, Nessus Professional, Burp Suite Professional.

Techniques include: OWASP Top 10 testing, manual configuration review, and credential brute-forcing (on explicitly approved targets).

CERTIFICATIONS & ACKNOWLEDGMENTS

Tester Certifications

OSCP, CEH, GPEN

4years experience. Tester also holds CompTIA Security+ and is currently pursuing OSWE.

Client Acknowledgments

By signing, Client acknowledges:

- 🎬 Testing may cause temporary service disruptions
- 🎬 False positives/negatives are possible
- 🎬 Testing doesn't guarantee complete security
- 🎬 Regular security assessments are recommended

DOCUMENT VERSION: 2.0

LAST UPDATED: December 2025

CONFIDENTIALITY: HIGH - For authorized parties only